

Security Policy

Document Information

- Version: 3.1
- Last Updated: January 5, 2026
- Document Owner: Information Security Team
- Contact: security@apextech.solutions
- Report Security Issues: security-incidents@apextech.solutions | ext. 9911

Table of Contents

1. Security Principles
2. Data Protection
3. Password & Authentication
4. Device Security
5. Network Security
6. Phishing & Social Engineering
7. Incident Reporting
8. Physical Security
9. Third-Party Security
10. Compliance & Audits

Security Principles

Shared Responsibility

Security is everyone's responsibility. Every employee plays a critical role in protecting:

- **Customer data** - Personal information, usage data, payment details
- **Company data** - Intellectual property, financials, strategy
- **Employee data** - HR records, compensation, personal info
- **Systems & infrastructure** - Applications, databases, networks

Security First Culture

- **Think before you click** - Verify before opening links or attachments
- **Question anomalies** - If something seems off, report it
- **Protect credentials** - Never share passwords or access codes
- **Report incidents** - Better to over-report than under-report
- **Stay informed** - Complete security training and read updates

Reporting Security Concerns

See something, say something.

Contact Security Team:

- **Email:** security@apextech.solutions
- **Slack:** #security or DM @security-team

- **Phone:** ext. 9911 (urgent/emergencies)
- **Anonymous:** ethics hotline 1-800-APEX-ETH

NO retaliation for good-faith security reports.

Data Protection

Data Classification

Handling Customer Data

General Rules:

- Access only when needed for your job
- Never share customer data externally without approval
- Use production data only in production (never copy to local machines)
- Delete data when no longer needed
- Report any suspected breach immediately

Prohibited Actions:

- **X** Downloading customer databases to personal devices
- **X** Sharing customer information via unencrypted email
- **X** Using production data for testing (use anonymized/synthetic data)
- **X** Accessing customer accounts without authorization
- **X** Discussing customer data in public spaces (coffee shops, airports)

Data Minimization:

Only collect, access, and retain data you actually need. Don't keep data "just in case."

Data Storage Guidelines

Approved Storage Locations:

- ✓ Google Drive (company account)
- ✓ GitHub (for code only)
- ✓ Notion (company workspace)
- ✓ Approved cloud services (Salesforce, HubSpot, etc.)

NOT Approved:

- **X** Personal email or cloud storage (Gmail, Dropbox, iCloud)
- **X** USB drives or external hard drives (unless encrypted and approved)
- **X** Personal messaging apps (WhatsApp, personal Slack)
- **X** Public file sharing sites (WeTransfer, Google Drive personal)

Encryption Requirements:

- Confidential and Highly Confidential data **MUST** be encrypted
- Use approved tools (1Password for sharing credentials, Google Drive for documents)
- Email encryption available via IT for external sharing

Data Retention

Right to Deletion:

Customers can request data deletion (GDPR, CCPA). Contact legal@apextech.solutions to process requests.

Password & Authentication

Password Requirements

All Systems:

- **Minimum length:** 12 characters
- **Complexity:** Upper, lower, number, special character
- **Expiration:** 90 days (you'll receive reminders)
- **No reuse:** Cannot reuse last 5 passwords
- **Unique:** Different password for each system

Examples of STRONG Passwords:

- BlueSky\$Mountain#2026 (16 characters, easy to remember)
- Coffee!Laptop@Home99 (20 characters, phrase-based)
- Or use 1Password's generator for random strong passwords

Examples of WEAK Passwords:

- ✗ Password123! (too common)
- ✗ Apextech2026 (company name)
- ✗ Summer2024! (predictable pattern)
- ✗ Qwerty123! (keyboard pattern)

1Password - Company Standard

Required Usage:

Every employee must use 1Password for:

- Storing work passwords
- Generating strong passwords
- Sharing team credentials securely
- Storing secure notes (WiFi codes, access codes)

Setup:

See IT Support Guide for 1Password setup instructions.

Best Practices:

- Enable biometric unlock (fingerprint/Face ID)
- Install browser extension for auto-fill
- Never save passwords in browser (use 1Password instead)
- Use shared vaults for team credentials
- Store recovery codes in secure notes

Multi-Factor Authentication (MFA)

Required On:

- Email (Google Workspace)
- VPN
- GitHub
- AWS Console
- Any system with customer data
- Admin/privileged accounts

MFA Methods (in order of preference):

1. **Duo Mobile** (push notification) - RECOMMENDED
2. **Authenticator app** (TOTP codes)
3. **SMS** (least secure, use only if no other option)
4. **X Never email** (not secure for MFA)

Setup Duo Mobile:

1. Download app (iOS/Android)
2. Scan QR code during setup
3. Approve push notifications to authenticate
4. Save backup codes in 1Password

Protect Your MFA:

- Never share MFA codes
- Don't approve unexpected push notifications (could be attacker)
- Report suspicious MFA requests immediately

Account Sharing

PROHIBITED:

- **X** Sharing your password with anyone (colleagues, contractors, family)
- **X** Logging in as someone else
- **X** Creating shared accounts with single credentials

For Shared Access Needs:

- ✓ Use shared vaults in 1Password
- ✓ Request service accounts (for systems, not people)
- ✓ Use role-based access (assign proper permissions)

Device Security

Laptop & Computer Security

Required Security Settings:

- **Disk encryption:** FileVault (Mac) or BitLocker (Windows) - Enabled by default
- **Automatic updates:** OS and security patches - Must be enabled
- **Screen lock:** Auto-lock after 5 minutes idle

- **Firewall:** Enabled
- **Antivirus:** Company-managed (CrowdStrike) - Do not disable

Checking Encryption Status:

- Mac: System Settings → Privacy & Security → FileVault
- Windows: Settings → Privacy & Security → Device encryption

Screen Lock Shortcuts:

- Mac: Control + Command + Q
- Windows: Windows + L

Lost or Stolen Device:

1. **Immediately** call IT Emergency: ext. 4911
2. Email security@apextech.solutions
3. File police report (for stolen)
4. IT will remotely wipe the device

Prevention:

- Use laptop lock cable in office (available from IT)
- Never leave laptop in car (even in trunk)
- Enable "Find My Device" (Mac/Windows)
- Keep software updated

Mobile Device Security

Company Data on Personal Phones:

If accessing company email or Slack on personal mobile:

- Set device passcode (6+ digits)
- Enable auto-lock (5 minutes max)
- Keep OS updated
- Install only from official app stores
- Enable remote wipe capability

Recommended (for sensitive roles):

Use company-issued phone for work, personal phone for personal use.

Physical Token/Badges

Access Badges:

- Never share or loan your badge
- Report lost badges immediately: security@apextech.solutions
- Don't allow tailgating (politely ask people to badge in)
- Badge required for all buildings

Security Tokens:

Some roles receive YubiKey or similar hardware tokens:

- Keep on your person (keychain)
- Never share

- Report lost tokens immediately

Network Security

Wi-Fi Security

Office Wi-Fi:

- **ApexTech-Secure**: Primary network (password in 1Password)
- **ApexTech-Guest**: For visitors only (limited access)
- Never share Wi-Fi passwords externally

Public Wi-Fi:

- **X Never** access confidential data on public Wi-Fi
- **✓ Always** use VPN when on public networks
- Avoid: coffee shops, airports, hotels, co-working spaces

Home Wi-Fi:

- Change default router password
- Use WPA3 or WPA2 encryption
- Use VPN when accessing company systems

VPN (Virtual Private Network)

Required When:

- Working remotely from any location
- Accessing internal systems outside office
- Handling confidential customer data
- Using public Wi-Fi

How to Connect:

See IT Support Guide for VPN setup and usage.

VPN Best Practices:

- Connect before accessing company resources
- Keep VPN software updated
- Don't disconnect while handling sensitive data
- Report VPN connection issues to IT

Cloud Security

Approved Cloud Services:

- Google Workspace
- GitHub
- AWS (authorized users only)
- Salesforce, HubSpot, Notion

Unapproved/Personal Cloud:

- ✗ Personal Dropbox, iCloud, OneDrive
- ✗ WeTransfer, SendAnywhere
- ✗ Personal file sharing services

Cloud Best Practices:

- Check sharing permissions before sharing links
- Use expiring links when possible
- Revoke access when collaboration ends
- Don't make documents "public" unless intended

Phishing & Social Engineering

Recognizing Phishing

Common Phishing Tactics:

- **Urgency:** "Your account will be suspended!"
- **Authority:** "This is IT, we need your password"
- **Curiosity:** "You won't believe this video of you!"
- **Fear:** "We detected suspicious activity"
- **Greed:** "You've won a prize!"

Red Flags:

- ■ Suspicious sender email (check carefully: arnaz0n . com vs amazon . com)
- ■ Requests for password, SSN, financial info
- ■ Unexpected attachments (invoices, receipts you didn't order)
- ■ Shortened or obscured links (bit.ly, suspicious URLs)
- ■ Spelling/grammar errors
- ■ Mismatched sender name and email address
- ■ Too good to be true offers

What to Do

If You Receive Suspected Phishing:

1. **DO NOT CLICK** links or download attachments
2. Hover over links (don't click!) to see real destination
3. Forward to: phishing@apextech.solutions
4. Report in #security Slack channel
5. Delete the email

If You Clicked a Phishing Link:

1. **DO NOT** enter any information
2. Close browser tab immediately
3. Contact IT: ext. 4357
4. Change your password via password reset tool
5. Report incident: security-incidents@apextech.solutions

If You Entered Credentials on Phishing Site:

1. **URGENT** - Call IT immediately: ext. 9911
2. IT will reset your password and secure your account
3. Enable MFA if not already enabled
4. Monitor accounts for suspicious activity

Social Engineering

Common Tactics:

- **Pretexting:** "I'm from IT, I need your password to fix your account"
- **Baiting:** "Free USB drives!" (infected with malware)
- **Tailgating:** Following you into secure areas
- **Vishing:** Phone calls pretending to be IT, executives, etc.

Protection:

- Verify identity before sharing information
- IT will NEVER ask for your password
- Call back on official company number to verify
- Don't plug in unknown USB drives
- Challenge unfamiliar people in secure areas

Incident Reporting

What to Report

Immediately Report:

- Suspected phishing emails or links
- Lost or stolen devices (laptop, phone, badge)
- Suspected malware or virus
- Unusual account activity
- Unauthorized access to systems or data
- Data breaches or leaks
- Suspicious phone calls or in-person requests

When in Doubt, Report:

It's better to over-report than under-report. Security team will assess and respond.

How to Report

Security Incidents:

- **Email:** security-incidents@apextech.solutions
- **Phone:** ext. 9911 (urgent)
- **Slack:** #security or DM @security-team

Phishing/Spam:

- Forward to: phishing@apextech.solutions
- Delete original email

Lost Devices:

- **Immediately** call IT Emergency: ext. 4911

What to Include:

- What happened (be specific)
- When it happened (date/time)
- What systems/data may be affected
- Actions you've already taken
- Screenshots or evidence (if available)

Response Timeline**Security team will:**

- Acknowledge report within 1 hour (urgent) or 4 hours (non-urgent)
- Investigate and assess impact
- Contain threat and remediate
- Communicate next steps
- Conduct post-incident review

You may be asked to:

- Preserve evidence (don't delete emails, logs)
- Change passwords
- Temporarily suspend access
- Provide additional details

Physical Security

Office Security**Building Access:**

- Badge in (even if door is open)
- Don't allow tailgating or hold doors for unknown people
- Report lost badges immediately
- Visitors must sign in at reception and be escorted

Desk/Workspace:

- Lock screen when leaving (even briefly)
- Don't leave sensitive documents on desk overnight
- Use shredder for confidential printouts
- Lock laptop to desk with cable (in shared spaces)

Conference Rooms:

- Don't leave laptops/devices unattended
- Erase whiteboards with confidential info
- End Zoom calls when meeting concludes

Visitors:

- All visitors must be escorted
- Visitor badges required
- Don't discuss confidential topics near visitors
- Secure devices and documents when visitors present

Clean Desk Policy**End of Day:**

- Lock away confidential documents
- Shut down or lock computers
- Don't leave passwords on sticky notes
- Shred sensitive papers

Shredding:

- Confidential documents must be shredded (not recycled)
- Shredders available on each floor
- Use locked shred bins for bulk shredding

Third-Party Security**Vendor Security****Before Sharing Data with Vendors:**

- Ensure they have signed NDA
- Verify they meet our security standards
- Share only minimum necessary data
- Use secure transfer methods (not email)
- Get approval from Legal and Security teams

Vendor Access:

- Limited to specific systems/data
- Time-bound (revoke when project ends)
- Monitored and logged
- MFA required

Consultant/Contractor Security**Contractors Must:**

- Sign NDA and security agreement
- Use company-issued equipment (if accessing sensitive data)
- Follow same security policies as employees
- Have access revoked upon contract end

Managers Responsible For:

- Ensuring contractors complete security training
- Monitoring contractor access

- Revoking access when contract ends

Compliance & Audits

Regulatory Compliance

ApexTech complies with:

- **SOC 2 Type II:** Security controls audited annually
- **GDPR:** European data protection (if applicable to customers)
- **CCPA:** California consumer privacy (if applicable)
- **ISO 27001:** Information security management (in progress)

Your Role:

- Complete compliance training (annually)
- Follow security policies and procedures
- Cooperate with audits and assessments
- Report non-compliance

Security Audits

Internal Audits:

- Quarterly access reviews (managers verify team access)
- Annual policy review and certification
- Penetration testing (bi-annual)

External Audits:

- SOC 2 audit (annual)
- Customer security assessments (as needed)

During Audits:

- Respond promptly to requests
- Provide accurate information
- Don't hide or minimize issues
- Work with Security team on remediation

Training & Awareness

Required Training:

- **Cybersecurity Awareness** (annual) - 2 hours
- **Phishing simulation** (monthly) - Brief test
- **Data privacy** (annual) - 1 hour
- **Role-specific training** (as applicable)

Training tracked in BambooHR. You'll receive reminders.

Stay Informed:

- Read security updates in #security Slack channel

- Attend optional security lunch & learns
- Complete phishing simulation training (if you fail test)

Security Violation Consequences

Policy Violations

Violations of security policy may result in:

- Verbal or written warning
- Mandatory retraining
- Access restrictions
- Performance improvement plan
- Suspension
- Termination

Severity depends on:

- Intent (accidental vs. malicious)
- Impact (what data/systems were affected)
- Frequency (first-time vs. repeat)

Examples:

- *Minor*: Leaving laptop unlocked briefly → Verbal reminder
- *Moderate*: Sharing password with colleague → Written warning, retraining
- *Major*: Intentional data theft → Immediate termination, legal action

No Blame for Honest Mistakes

We understand accidents happen.

- Clicked phishing link accidentally? Report it promptly, no penalty.
- Lost your laptop? Call immediately, we'll help.
- Made a mistake? Own it, learn from it, help us prevent it.

Retaliation for good-faith reporting is prohibited.

Frequently Asked Questions

Q: Can I use my personal laptop for work?

A: No. For security and compliance, use only company-issued devices.

Q: What if I need to share customer data with a vendor?

A: Contact security@apextech.solutions first. We'll assess and approve secure transfer methods.

Q: Is it okay to write down passwords?

A: No. Use 1Password instead. If you must write something, lock it in a safe.

Q: Can I access work email on my personal phone?

A: Yes, but you must enable device passcode, auto-lock, and allow remote wipe capability. See IT Support Guide.

Q: What happens if I fail the phishing simulation?

A: You'll receive additional training. No penalty for first-time failures. Repeated failures may require additional intervention.

Q: Do I need VPN when working from home?

A: Yes, always use VPN when accessing company systems remotely.

Q: How do I know if an email is really from IT?

A: Check sender address carefully (@apextech.solutions). IT will NEVER ask for passwords. When in doubt, verify via Slack or call IT directly.

Related Documents

- IT Support Guide - Technical support and troubleshooting
- Remote Work Policy - Remote access and VPN guidelines
- HR Policies - Code of conduct and workplace policies
- Employee Handbook - Company culture and values

Security Team Contact

- Email: security@apextech.solutions
- Incidents: security-incidents@apextech.solutions
- Phone: ext. 9911 (emergencies)
- Phishing: phishing@apextech.solutions
- Slack: #security
- Anonymous: 1-800-APEX-ETH

Remember: Security is everyone's responsibility. When in doubt, reach out.